

Partie 3 – Bonnes pratiques et sécurité du service OpenSSH sur le serveur

Mise en œuvre des bonnes pratiques édictées par l'ANSSI.....	1
Q1. Mettre en œuvre les préconisations suivantes tirées des recommandations pour un usage sécurisé de SSH publié par l'ANSSI :.....	1
Q2. Expliquer dans une définition succincte ce qu'est l'état de l'art dans le domaine de la cybersécurité.....	3
Q3. Définir ce qu'est le principe de Kerckhoffs.....	3
Q4. Selon ce principe, pourquoi est-il pertinent de choisir des algorithmes cryptographiques connus et respectant l'état de l'art ?.....	3

Mise en œuvre des bonnes pratiques édictées par l'ANSSI

Q1. Mettre en œuvre les préconisations suivantes tirées des recommandations pour un usage sécurisé de SSH publié par l'ANSSI :

1. Vérifier que les clés privées de chiffrement présentes dans le répertoire `/etc/ssh/` appartiennent à l'utilisateur `root` en lecture-écriture seulement ;

```
etusio@srvssh:/etc/ssh$ ls -l
total 584
-rw-r--r-- 1 root root 565189 janv. 31 2020 moduli
-rw-r--r-- 1 root root 1580 déc. 2 10:44 ssh_config
-rw-r--r-- 1 root root 3246 déc. 2 08:28 sshd_config
-rw----- 1 root root 505 mars 29 2020 ssh_host_ecdsa_key
-rw-r--r-- 1 root root 173 mars 29 2020 ssh_host_ecdsa_key.pub
-rw----- 1 root root 399 mars 29 2020 ssh_host_ed25519_key
-rw-r--r-- 1 root root 93 mars 29 2020 ssh_host_ed25519_key.pub
-rw----- 1 root root 1823 mars 29 2020 ssh_host_rsa_key
-rw-r--r-- 1 root root 393 mars 29 2020 ssh_host_rsa_key.pub
etusio@srvssh:/etc/ssh$
```

C'est bon car tous les fichiers de clés privés ne sont autorisés que pour `root` en **read** et **write**.

2. S'assurer que c'est bien la version 2 du protocole SSH qui est utilisée ;

Il faut écrire, dans le fichier `sshd_config`:
Protocol 2

3. Le serveur SSH doit dorénavant écouter sur le port 222/TCP ;

Modifier cette ligne dans le même fichier en mettant 222 et en décochant

```
#Port 22
```

4. Vérifier que les droits sur les fichiers sont appliqués de manière stricte par SSH ;

On décoche cette case

```
#StrictModes yes
```

5. L'accès SSH par l'utilisateur root doit être interdite ;

Il faut rajouter la ligne suivant dans le fichier et ici précisément

PermitRootLogin no

```
# Authentication:

#LoginGraceTime 2m
#PermitRootLogin prohibit-password
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10
```

6. Mettre en œuvre une séparation des privilèges à l'aide d'un bac à sable (sandbox) ;

Il faut ajouter la ligne **UsePrivilegeSeparation sandbox** dans le fichier.

7. L'accès à distance par des comptes ne disposant pas de mot de passe doit être interdit ;

On décoche la ligne permettant de se connecter avec un mot de passe vide pour les utilisateurs

```
passwordAuthentication no
#PermitEmptyPasswords no
```

8. Autoriser 3 tentatives de connexion successives en cas d'erreur dans le mot de passe ;

Il faut décocher et changer la valeur vers 3

```
#MaxAuthTries 6
```

9. Le service doit afficher les informations de dernière connexion à l'utilisateur quand il se connecte ;

Il faut décocher cette phrase du fichier

```
#PrintLastLog yes
```

10. N'autoriser que l'utilisateur *etusio* à se connecter sur le serveur.

On met la commande **AllowUsers etusio** dans le fichier.

Q2. Expliquer dans une définition succincte ce qu'est l'état de l'art dans le domaine de la cybersécurité.

L'état de l'art désigne l'ensemble des méthodes, standards, configurations, algorithmes, pratiques et connaissances considérés comme les plus fiables et éprouvés au moment présent dans le domaine de la cybersécurité.

Q3. Définir ce qu'est le principe de Kerckhoffs

Le principe de Kerckhoffs affirme qu'un système cryptographique doit rester sécurisé même si tout est connu de l'attaquant –sauf la clé. Le mécanisme peut être exposé au grand jour sans que la confidentialité s'effondre.

Q4. Selon ce principe, pourquoi est-il pertinent de choisir des algorithmes cryptographiques connus et respectant l'état de l'art ?

Les algorithmes publics et reconnus ont été analysés, attaqués, stressés, défigurés, puis renforcés par la communauté scientifique.

Leur sécurité ne repose pas sur un secret fragile, mais sur la robustesse mathématique et la qualité de leur conception.

Ils incarnent l'état de l'art : mis à jour, recommandés, documentés, audités.

Utiliser un algorithme obscur ou "fait maison", c'est bâtir une forteresse sur des sables mouvants ; l'adversaire n'aura qu'à souffler pour que tout s'écroule.

Pour empêcher l'usage d'algorithmes de chiffrement dépréciés, il est nécessaire d'éditer le fichier de configuration du serveur SSH et ajouter les lignes suivantes :

```
KexAlgorithms curve25519-sha256@libssh.org,ecdh-sha2-nistp521,ecdh-sha2-nistp384,ecdh-sha2-nistp256,diffie-hellman-group-exchange-sha256
Ciphers chacha20-poly1305@openssh.com,aes256-gcm@openssh.com,aes128-gcm@openssh.com,aes256-ctr,aes192-ctr,aes128-ctr
MACs hmac-sha2-512-etm@openssh.com,hmac-sha2-256-etm@openssh.com,umac-128-etm@openssh.com,hmac-sha2-512,hmac-sha2-256,umac-128@openssh.com
```

Puis redémarrer le service ssh.

```
etusio@srvssh:/etc/ssh$ sudo systemctl restart sshd
```